Vision — SAST-звіт

Коміт `4ac0ca9` · 2026-11-09 · `backend/`, `frontend/`, `sdk-java/`, `scripts/`, Dockerfile-и, nginx

Результат

Перевірка	Інструмент	Підтверджені знахідки
SAST (TS/JS/React, Java, Python, Dockerfile, bash)	semgrep 1.184.0, 1081 правило	0
SAST Python	bandit 1.9.4	0
Shell	shellcheck 0.11.0	0
Секрети	detect-secrets, semgrep secrets	0
Залежності (prod + dev)	npm audit	0
Ліцензії prod-залежностей	license-checker	0 copyleft у поставці

Статус: пройдено.

semgrep: 1311 спрацювань — ERROR 4, WARNING 1179, INFO 128; підтверджених 0. З них 1020 — `i18next-key-format` (формат ключів словника, не безпека), 65 — тестовий код, який не входить у поставку й не розглядається.

Ліцензії: MIT, Apache-2.0, ISC, BSD, BlueOak-1.0.0, PSF-2.0, 0BSD, Unlicense, шрифти OFL-1.1; `jszip` — MIT (подвійна MIT OR GPL-3.0); `elkjs` (EPL-2.0, Prisma Studio) видаляється при збірці образів.

Виправлено

Проблема	CWE	Файл	Тест
AES-GCM приймав укорочений тег автентифікації	CWE-326	`backend/src/shared/secret-box.ts`	`secret-box.spec.ts`
`$&`, `$\``, `$'` в email змінювали фільтр LDAP	CWE-90	`backend/src/users/ldap/ldapusers.service.ts`	`ldapusers.service.spec.ts`

Хибні спрацювання рівня ERROR

Правило	Місце	Причина
`useless-ternary`	`backend/src/backups/backups.service.ts:97`	`secret ? 0o600 : 0o644` — різні значення
`dangerous-subprocess-use-audit`	`frontend/public/cli/vision.py:123`	аргументи списком, без shell
`dangerous-subprocess-use-audit`	`scripts/seed-insights-demo.py:295`	команда задана в коді, без shell
`dangerous-subprocess-use-audit`	`scripts/verify.py:122`	команда задана в коді, без shell

Решта спрацювань (WARNING/INFO) — стиль, i18n, тестовий код або хибні. Сирі дані: `audit/raw/*-2026-11-09.json`.